本资料由达海教育 www.wuyouqiuzhi.com 及旗下 APP【笔试通】独家提供不定期更新，仅限购买用户个人学习使用，不得分享/转增/转卖

信息工程知识高频考点讲义

（紧扣考试大纲）

达海教育

-----本资料属 www.wuyouqiuzhi.com 及旗下天天向上求职工作室&职场精英工作室独家所有，仅限购买者个人使用，不得分享/转赠/转卖；版权所有，盗版可耻

-----整套资料包括真题汇编，复习讲义，在线考试系统（电脑版网址为 www.wuyouqiuzhi.com），移动端 APP（名称为：笔试通，苹果商店及安卓各大市场搜索即可下载安装），在线考试模拟和移动端 APP 刷题具有倒计时答题/错题本/做题记录/分数排名等功能， 电脑/手机/平板均可学习+做题

-----正版地址：官网 www.wuyouqiuzhi.com 或者移动端 APP（名称为：笔试通）；旗下淘宝店：天天向上求职工作室（唯一客服：galerjim）或职场精英工作室（唯一客服：蔚蓝小小天使）亦可购买学习

-----除上述渠道外，绝对没有通过其他任何渠道出售资料，任何其他渠道获取本资料的均为无良盗版，请从正版处购买，惟有正版资料会根据考纲不定时调整更新内容，为保证您的复习效果，请务必通过 网站 www.wuyouqiuzhi.com 或 APP【笔试通】及旗下天天向上求职工作室 or 职场精英工作室 购买学习

-----关注官方微信公众号：笔试通 可获取最新版<求职规划与实战红宝书>、招聘资讯

历年真题+讲义+全真模考+APP刷题

- APP客户端：笔试通 -

2027版 持续更新 唯一获取渠道--网址：www.wuyouqiuzhi.com 或 APP：笔试通

历年真题套题、考前押题等登录网站或者APP内在线做题，可计时考试/不计时刷题/背题

内容囊括：真题汇编+精华复习讲义+机考模拟系统+APP 刷题题库;本资料属于其中之一，紧扣考纲每年更新.获取本资料即获取所有模块内容,不需另付费

历年真题、考前押题等登录网站或者APP内在线做题，可计时考试答题/不计时刷题/背题

笔试1对1助攻辅导联系VX：zhugongqiuzhi 2027版

本资料由达海教育 www.wuyouqiuzhi.com 及旗下 APP【笔试通】独家提供不定期更新，仅限购买用户个人学习使用，不得分享/转增/转卖

1 软件安全的基本概念及应用分析

1.1 基本概念

软件安全是指通过技术手段和管理措施，保障软件在生命周期（需求分析、设计、开发、测试、部署、运维）的各个阶段，能够抵御各类安全威胁，避免软件出现功能失效、数据泄露、被篡改或被非法控制等问题，确保软件持续、稳定、合规地运行。其核心目标是保护软件本身、软件所处理的数据以及软件运行环境的安全性、完整性和可用性。

软件安全与网络安全、信息安全是从属与关联关系：信息安全是广义范畴，涵盖数据、软件、硬件、网络等全维度安全；网络安全聚焦网络传输和网络环境的安全；软件安全是信息安全的核心组成部分，是保障数据和系统安全的基础——多数信息安全事件的根源的是软件存在安全漏洞或设计缺陷。

1.2 核心安全属性

- **保密性**：确保软件处理和存储的敏感数据仅能被授权主体访问，未授权用户无法获取或解读数据。例如，用户密码、银行卡信息等敏感数据需通过加密处理，防止泄露。
- **完整性**：保障软件的数据和功能不被未授权篡改、破坏或伪造，确保数据在传输、存储和处理过程中保持原始状态。例如，通过校验码、哈希值验证等方式，检测数据是否被篡改。
- **可用性**：确保授权用户在需要时能够正常访问和使用软件的功能及数据，避免软件因攻击、故障或配置错误导致无法服务。例如，抵御拒绝服务攻击（DoS），保障软件持续响应请求。
- **可控性**：对软件的访问权限、运行状态、数据流转进行全程管控，确保软件的操作和行为可追溯、可监管。例如，通过权限分级管理，限制不同用户的操作范围。
- **不可否认性**：针对软件中的交互操作（如交易、指令下发），确保操作主体无法否认其执行的行为，为后续审计和追责提供依据。例如，通过数字签名技术，确认操作发起者的身份并留存证据。

1.3 常见安全威胁与漏洞

1.3.1 常见安全威胁

- **恶意代码攻击**：包括病毒、蠕虫、木马、 ransomware（勒索病毒）、间谍软件等，通过植入软件或系统，窃取数据、破坏功能或控制设备。例如，勒索病毒加密用户数据，索要赎金后才提供解密密钥。
- **注入攻击**：攻击者将恶意代码注入软件的输入环节，绕过验证机制执行非法操作，常见类型有 SQL 注入、命令注入、XSS（跨站脚本）注入等。例如，SQL 注入通过构造恶意 SQL 语句，窃取数据库中的敏感数据。
- **权限滥用攻击**：包括越权访问、权限提升等，攻击者利用软件的权限管理缺陷，获取超出自身授权的操作权限，访问或篡改敏感数据。例如，普通用户通过漏洞提升为管理员权限，控制整个软件系统。
- **拒绝服务攻击（DoS/DDoS）**：攻击者通过大量恶意请求占用软件的服务器资源（如带宽、内存、CPU），导致软件无法响应正常用户的请求，陷入瘫痪状态。DDoS 是分布式拒绝服务攻击，通过多个节点同时发起攻击，破坏力更强。
- **数据泄露**：由于软件漏洞、配置不当或人为操作失误，导致敏感数据被未授权主体获取，包括用户信息、商业机密、政务数据等。例如，软件未对用户密码进行加密存储，导致密码明文泄露。

内容囊括：真题汇编+精华复习讲义+机考模拟系统+APP 刷题题库;本资料属于其中之一，紧扣考纲每年更新.获取本资料即获取所有模块内容,不需另付费
历年真题、考前押题等登录网站或者APP内在线做题，可计时考试答题/不计时刷题/背题

本资料由达海教育 www.wuyouqiuzhi.com 及旗下 APP【笔试通】独家提供不定期更新，仅限购买用户个人学习使用，不得分享/转增/转卖

1.3.2 常见软件漏洞

- **缓冲区溢出漏洞**：软件开发中未对输入数据的长度进行校验，导致过量数据写入缓冲区，覆盖相邻内存空间，攻击者可利用该漏洞植入恶意代码，控制软件或系统。
- **身份认证漏洞**：包括弱密码、无验证码、会话管理不当等，攻击者可通过暴力破解、会话劫持等方式，冒充合法用户登录软件。
- **输入验证缺失漏洞**：软件未对用户输入的数据进行合法性校验，导致恶意数据注入或非法操作，是注入攻击、数据篡改的主要诱因。
- **配置错误漏洞**：软件部署或运维过程中，配置参数不当（如开启不必要的端口、开放过高权限），导致安全隐患，攻击者可利用这些漏洞发起攻击。

1.4 软件安全防护技术

1.4.1 开发阶段防护（事前防护）

- **安全开发生命周期（SDL）**：将安全理念融入软件生命周期的各个阶段，从需求分析阶段明确安全需求，设计阶段进行安全架构设计，开发阶段遵循安全编码规范，测试阶段开展安全测试，确保软件从源头规避安全漏洞。
- **安全编码规范**：开发者遵循行业通用的安全编码标准（如 OWASP 安全编码指南），避免使用存在安全隐患的编码方式，减少缓冲区溢出、注入攻击等漏洞。
- **静态应用安全测试（SAST）**：在软件开发过程中，通过工具扫描源代码、字节码，提前发现潜在的安全漏洞，无需运行软件即可完成测试，适合在开发早期排查问题。

1.4.2 部署与运行阶段防护（事中防护）

- **动态应用安全测试（DAST）**：在软件运行状态下，模拟攻击者发起攻击，检测软件的运行时安全漏洞，例如注入攻击、越权访问等，适合在软件部署后、上线前进行全面检测。
- **加密技术**：对敏感数据进行加密处理，包括传输加密（如 SSL/TLS 协议）、存储加密（如 AES 加密算法）、数据脱敏（对身份证、手机号等敏感信息进行部分隐藏），防止数据泄露。
- **访问控制技术**：采用基于角色的访问控制（RBAC）、基于属性的访问控制（ABAC）等机制，对用户权限进行分级管理，明确不同角色的操作范围，防止权限滥用。
- **入侵检测与防御系统（IDS/IPS）**：IDS 用于监测软件运行过程中的异常行为和攻击迹象，及时发出告警；IPS 在 IDS 的基础上，可主动阻断恶意攻击，防止攻击对软件造成破坏。
- **漏洞补丁管理**：及时收集软件的安全漏洞信息，发布并安装补丁，修复已知漏洞，避免攻击者利用漏洞发起攻击。

1.4.3 运维阶段防护（事后防护）

- **安全审计**：记录软件的所有操作行为（如用户登录、数据修改、指令执行），形成审计日志，便于后续追溯安全事件、排查问题和追责。
- **应急响应**：制定安全应急响应预案，当发生安全事件（如数据泄露、恶意攻击）时，快速启动预案，采取

内容囊括：真题汇编+精华复习讲义+机考模拟系统+APP 刷题题库;本资料属于其中之一，紧扣考纲每年更新.获取本资料即获取所有模块内容,不需另付费
历年真题、考前押题等登录网站或者APP内在线做题，可计时考试答题/不计时刷题/背题

本资料由达海教育 www.wuyouqiuzhi.com 及旗下 APP【笔试通】独家提供不定期更新，仅限购买用户个人学习使用，不得分享/转增/转卖

隔离攻击源、恢复数据、修复漏洞等措施，降低事件造成的损失。

- **安全监控**：实时监控软件的运行状态、网络流量、数据流转情况，及时发现异常，快速处置安全隐患。

1.5 应用分析

1.5.1 互联网软件领域

互联网软件（如电商平台、社交 APP、在线支付软件）是软件安全防护的重点场景，需兼顾用户数据安全和交易安全。例如，电商平台采用加密技术保护用户银行卡信息和交易数据，通过入侵防御系统抵御注入攻击和 DDoS 攻击；社交 APP 采用数据脱敏技术隐藏用户敏感信息，通过权限管理限制用户访问范围，防止用户信息泄露。

1.5.2 金融软件领域

金融软件（如银行核心系统、证券交易软件、支付软件）对安全性要求极高，需满足合规要求（如银保监会的安全规范）。例如，银行核心系统采用双重身份认证、数字签名技术，确保交易的安全性和不可否认性；证券交易软件通过漏洞补丁管理和安全审计，防范恶意攻击，保障交易数据的完整性和可用性。

1.5.3 政务软件领域

政务软件（如电子政务平台、政务审批系统）涉及大量政务数据和公众信息，需保障数据安全和系统稳定。例如，政务审批系统采用访问控制技术，限制不同部门的权限，防止政务数据泄露；通过安全监控和应急响应机制，应对恶意攻击，确保政务服务正常开展。

1.5.4 工业软件领域

工业软件（如工业控制系统、智能制造软件）直接关系到工业生产的安全，需防范恶意攻击导致的生产中断或设备损坏。例如，工业控制系统采用隔离防护技术，将生产网络与互联网隔离，防止外部攻击；通过漏洞扫描和补丁管理，修复工业软件的安全漏洞，保障生产过程的稳定。

1.5.5 移动软件领域

移动 APP（如手机银行、社交软件、办公 APP）面临恶意代码、权限滥用、数据泄露等安全威胁。例如，移动 APP 采用权限申请分级机制，仅获取必要的用户权限，避免过度收集用户信息；通过加密存储用户数据，防止手机丢失后数据泄露；集成安全检测模块，监测恶意代码注入行为。

2 信息内容安全的基本概念及应用分析

2.1 基本概念

信息内容安全是指对信息的内容进行管控、防护和治理，确保信息内容的合法性、真实性、完整性和安全性，抵御不良信息、有害信息和虚假信息的传播，保护用户权益、社会公共利益和国家安全。其核心是“内容管控+风险防范”，聚焦信息的内容本身，区别于网络安全（聚焦传输和网络环境）、软件安全（聚焦软件载体）。

信息内容安全的覆盖范围包括文本、图像、音频、视频、动画等各类形式的信息，涉及信息的生成、传输、存储、传播、使用等全流程，核心目标是遏制有害信息传播、防范虚假信息误导、保护隐私信息、维护网络空间

内容囊括：真题汇编+精华复习讲义+机考模拟系统+APP 刷题题库;本资料属于其中之一，紧扣考纲每年更新.获取本资料即获取所有模块内容,不需另付费
历年真题、考前押题等登录网站或者APP内在线做题，可计时考试答题/不计时刷题/背题
笔试1对1助攻辅导联系VX：zhugongqiuzhi 2027版

本资料由达海教育 www.wuyouqiuzhi.com 及旗下 APP【笔试通】独家提供不定期更新，仅限购买用户个人学习使用，不得分享/转增/转卖

秩序。

2.2 核心防护目标

- **遏制有害信息传播**：阻止暴力、色情、恐怖主义、极端主义、仇恨言论等违法违规有害信息的生成和传播，净化网络空间。
- **防范虚假信息误导**：识别和处置谣言、虚假宣传、虚假新闻等内容，避免虚假信息误导公众、扰乱社会秩序。
- **保护隐私信息安全**：防止个人隐私信息（如身份证号、手机号、住址、肖像）被非法收集、传播和滥用，保障用户隐私权益。
- **维护内容真实性与完整性**：确保信息内容不被篡改、伪造，保障信息的可信度，尤其是政务信息、新闻信息、金融信息等关键内容。
- **保障国家安全与公共利益**：防范利用有害信息危害国家安全、破坏社会稳定、损害公共利益，筑牢信息内容安全防线。

2.3 常见信息内容安全风险

2.3.1 违法违规有害信息

- **色情低俗信息**：包括色情文本、图片、视频、动画等，违背公序良俗，危害青少年身心健康。
- **暴力恐怖信息**：宣扬暴力、恐怖主义、极端主义的内容，诱导违法犯罪，破坏社会稳定。
- **仇恨与歧视信息**：煽动民族仇恨、种族歧视、性别歧视等内容，破坏社会和谐。
- **违法宣传信息**：传播赌博、吸毒、传销、虚假药品广告等违法内容，诱导用户参与违法活动。

2.3.2 虚假信息与谣言

- **社会谣言**：关于疫情、灾害、社会事件的虚假信息，如虚假疫情防控政策、虚假灾害预警等，容易引发公众恐慌。
- **商业虚假信息**：虚假广告、虚假产品宣传、虚假企业资质等内容，误导消费者，损害消费者权益。
- **政务虚假信息**：伪造政务通知、政策文件等内容，误导公众对政务工作的认知，损害政府公信力。

2.3.3 隐私与敏感信息泄露

- **个人隐私泄露**：非法收集、传播用户的身份证号、手机号、住址、肖像、消费记录等隐私信息，导致用户遭受骚扰、诈骗。
- **敏感数据泄露**：政务敏感数据、商业机密、军事机密等被非法传播，危害国家安全和企业利益。

2.3.4 内容篡改与伪造

攻击者篡改新闻报道、政务通知、学术论文等信息内容，或伪造图像、视频（如深度伪造技术），误导公众、抹黑他人或破坏社会秩序。例如，利用深度伪造技术伪造名人言论视频，引发舆论风波。

内容囊括：真题汇编+精华复习讲义+机考模拟系统+APP 刷题题库;本资料属于其中之一，紧扣考纲每年更新.获取本资料即获取所有模块内容,不需另付费
历年真题、考前押题等登录网站或者APP内在线做题，可计时考试答题/不计时刷题/背题

本资料由达海教育 www.wuyouqiuzhi.com 及旗下 APP【笔试通】独家提供不定期更新，仅限购买用户个人学习使用，不得分享/转增/转卖

2.4 信息内容安全防护技术

2.4.1 内容识别技术

- **文本识别技术：**基于自然语言处理（NLP），对文本内容进行关键词提取、语义分析、情感判断，识别色情、暴力、谣言等有害文本。例如，通过关键词匹配和语义分析，筛选出包含恐怖主义言论的文本。
- **图像/视频识别技术：**基于计算机视觉（CV），对图像、视频中的人物、场景、动作进行识别，检测色情、暴力、恐怖等有害内容。例如，通过图像识别技术，识别色情图片和暴力画面；通过视频帧分析，检测恐怖主义相关视频。
- **音频识别技术：**对音频内容进行语音转文字、语义分析，识别有害语音信息（如暴力威胁、极端主义言论）。例如，识别音频中的仇恨言论，阻止其传播。

2.4.2 内容过滤与拦截技术

- **关键词过滤：**设置有害关键词库，对信息内容进行关键词匹配，拦截包含有害关键词的信息。适合快速筛选简单的有害内容。
- **语义过滤：**基于 NLP 语义分析，不仅匹配关键词，还能理解语句的上下文和语义，避免误判和漏判，提升过滤准确性。
- **分级过滤：**根据信息内容的风险等级，采取不同的过滤措施，例如对严重违法信息直接拦截，对疑似有害信息进行人工审核。

2.4.3 虚假信息检测技术

- **溯源验证技术：**对信息的来源进行追溯，验证信息发布者的身份和资质，判断信息的可信度。例如，验证新闻信息的发布主体是否为正规媒体。
- **内容比对技术：**将疑似虚假信息与权威信息库进行比对，识别信息中的虚假内容。例如，将疫情相关信息与官方发布的疫情数据比对，排查谣言。
- **深度伪造检测技术：**针对伪造的图像、视频，通过分析图像纹理、面部特征、动作连贯性等，识别深度伪造内容，避免虚假内容传播。

2.4.4 隐私保护技术

- **数据脱敏技术：**对身份证号、手机号、住址等敏感信息进行处理，隐藏部分内容（如手机号隐藏中间 4 位），既保留信息的可用性，又防止隐私泄露。
- **隐私计算技术：**在不泄露原始隐私数据的前提下，实现数据的分析和共享，包括联邦学习、差分隐私等技术，适合政务、医疗等需要共享数据但需保护隐私的场景。
- **访问控制技术：**对敏感内容设置访问权限，仅授权用户可访问，防止未授权用户获取隐私信息。

2.4.5 人工审核与应急处置

- **人工审核：**对技术筛选出的疑似有害信息、模糊信息进行人工审核，提升内容识别的准确性，避免误判。
- **应急处置：**建立信息内容安全应急响应机制，对突发的有害信息传播事件（如谣言扩散、深度伪造视频传

内容囊括：真题汇编+精华复习讲义+机考模拟系统+APP 刷题题库;本资料属于其中之一，紧扣考纲每年更新.获取本资料即获取所有模块内容,不需另付费 历年真题、考前押题等登录网站或者APP内在线做题，可计时考试答题/不计时刷题/背题

本资料由达海教育 www.wuyouqiuzhi.com 及旗下 APP【笔试通】独家提供不定期更新，仅限购买用户个人学习使用，不得分享/转增/转卖

播），快速采取删除、拦截、澄清等措施，降低影响。

2.5 应用分析

2.5.1 互联网平台领域

互联网平台（如社交平台、短视频平台、新闻平台、电商平台）是信息内容安全防护的核心场景，需承担内容审核责任。例如，短视频平台通过图像/视频识别技术，检测色情、暴力、恐怖等有害内容，自动拦截并删除；新闻平台通过溯源验证和内容比对，排查虚假新闻，保障新闻真实性；社交平台通过关键词过滤和语义分析，拦截仇恨言论和谣言，净化社交环境。

2.5.2 政务信息领域

政务信息平台（如政府官网、政务公众号、政务 APP）需保障政务信息的真实性、完整性和安全性，防范虚假政务信息传播。例如，政府官网通过内容审核和溯源验证，确保发布的政策文件、通知公告真实有效；通过隐私保护技术，保护政务数据中的公众隐私信息，避免泄露。

2.5.3 教育领域

教育领域（如在线教育平台、校园论坛、学生社交群）需防范有害信息对青少年的危害，营造健康的教育环境。例如，在线教育平台通过内容过滤技术，拦截色情、暴力等有害内容，保护青少年身心健康；校园论坛通过人工审核和关键词过滤，规范学生发言，避免传播谣言和不良信息。

2.5.4 金融领域

金融领域（如银行 APP、证券平台、支付平台）需保障金融信息的真实性和隐私性，防范虚假金融信息和隐私泄露。例如，支付平台通过隐私保护技术，加密存储用户的银行卡信息和交易记录，防止隐私泄露；证券平台通过内容审核，拦截虚假理财广告和金融谣言，避免误导投资者。

2.5.5 医疗领域

医疗领域（如医疗信息平台、在线问诊平台）需保护患者的隐私信息，防范虚假医疗信息传播。例如，在线问诊平台通过数据脱敏技术，隐藏患者的个人隐私信息，避免泄露；通过内容比对和溯源验证，排查虚假医疗广告和虚假诊疗信息，保障患者的就医安全。

3 数据库与操作系统安全

3.1 数据库安全

3.1.1 基本概念

数据库安全是指通过技术手段和管理措施，保障数据库系统、数据库中的数据以及数据库运行环境的安全性，抵御各类安全威胁，确保数据的保密性、完整性、可用性和可控性。数据库是信息系统的核心数据存储载体，存储着大量敏感数据（如用户信息、商业机密、政务数据），是安全防护的重点对象。

数据库安全涵盖数据库系统安全、数据安全、访问安全、运维安全等多个维度，核心是防范数据泄露、数据篡

内容囊括：真题汇编+精华复习讲义+机考模拟系统+APP 刷题题库;本资料属于其中之一，紧扣考纲每年更新.获取本资料即获取所有模块内容,不需另付费
历年真题、考前押题等登录网站或者APP内在线做题，可计时考试答题/不计时刷题/背题

本资料由达海教育 www.wuyouqiuzhi.com 及旗下 APP【笔试通】独家提供不定期更新，仅限购买用户个人学习使用，不得分享/转增/转卖

改、数据库入侵等安全事件。

3.1.2 常见安全威胁

- **SQL 注入攻击**：攻击者通过构造恶意 SQL 语句，注入到数据库查询环节，绕过验证机制，窃取、篡改或删除数据库中的数据，甚至控制数据库服务器。
- **数据泄露**：由于数据库配置不当、漏洞未修复、权限管理松散等原因，导致数据库中的敏感数据被未授权主体获取，包括明文存储密码、未加密敏感数据被窃取。
- **数据篡改**：攻击者通过非法手段修改数据库中的数据，破坏数据的完整性，例如篡改金融交易数据、政务数据、用户信息等，造成严重损失。
- **数据库入侵**：攻击者利用数据库系统的漏洞（如缓冲区溢出漏洞、身份认证漏洞），入侵数据库服务器，获取数据库控制权，执行非法操作。
- **权限滥用**：数据库用户超出自身授权范围，访问或修改敏感数据，例如普通用户通过权限提升，获取管理员权限，操作核心数据。

3.1.3 安全防护技术

- **身份认证与授权管理**：采用强身份认证（如双重认证、数字证书），验证数据库用户的身份；通过基于角色的访问控制（RBAC），为不同用户分配对应的操作权限，限制用户的访问范围，防止权限滥用。
- **数据加密技术**：包括存储加密（对数据库中的敏感数据进行加密存储，如 AES、RSA 加密算法）、传输加密（对数据库与应用程序之间的数据传输进行加密，如 SSL/TLS 协议），防止数据泄露。
- **SQL 注入防护**：采用参数化查询、预编译语句，避免直接拼接 SQL 语句；通过输入验证，过滤恶意 SQL 语句；部署数据库防火墙，拦截注入攻击请求。
- **数据库审计**：记录数据库的所有操作行为（如用户登录、数据查询、修改、删除），形成审计日志，便于后续追溯安全事件、排查问题和追责。
- **漏洞补丁管理**：及时收集数据库系统的安全漏洞信息，发布并安装补丁，修复已知漏洞，避免攻击者利用漏洞入侵数据库。
- **数据备份与恢复**：定期对数据库数据进行备份，制定数据恢复预案，当发生数据丢失、数据篡改时，可快速恢复数据，降低损失。

3.2 操作系统安全

3.2.1 基本概念

操作系统安全是指保障操作系统本身、操作系统上的应用程序以及操作系统管理的硬件、数据和资源的安全性，抵御各类安全威胁，确保操作系统持续、稳定、安全地运行。操作系统是计算机系统的核心，是所有应用程序运行的基础，其安全性直接影响整个信息系统的安全。

操作系统安全涵盖系统内核安全、用户安全、文件安全、进程安全、网络安全等多个维度，核心目标是防范系统入侵、恶意代码攻击、权限滥用等安全事件。

内容囊括：真题汇编+精华复习讲义+机考模拟系统+APP 刷题题库;本资料属于其中之一，紧扣考纲每年更新.获取本资料即获取所有模块内容,不需另付费
历年真题、考前押题等登录网站或者APP内在线做题，可计时考试答题/不计时刷题/背题

本资料由达海教育 www.wuyouqiuzhi.com 及旗下 APP【笔试通】独家提供不定期更新，仅限购买用户个人学习使用，不得分享/转增/转卖

3.2.2 常见安全威胁

- **恶意代码攻击**：病毒、蠕虫、木马、勒索病毒等恶意代码入侵操作系统，破坏系统文件、窃取数据、控制设备，导致操作系统瘫痪或无法正常运行。
- **系统入侵**：攻击者利用操作系统的漏洞（如缓冲区溢出漏洞、权限管理漏洞），入侵操作系统，获取系统控制权，执行非法操作（如创建管理员账户、删除系统文件）。
- **权限滥用**：用户超出自身授权范围，操作操作系统的核心资源，例如普通用户提升为管理员权限，修改系统配置、删除核心文件。
- **文件破坏与篡改**：攻击者修改或删除操作系统的核心文件（如系统内核文件、配置文件），导致操作系统无法正常启动或运行异常。
- **拒绝服务攻击**：攻击者通过大量恶意请求，占用操作系统的 CPU、内存、带宽等资源，导致操作系统无法响应正常请求，陷入瘫痪。

3.2.3 安全防护技术

- **身份认证与访问控制**：采用强密码策略、双重认证、生物识别（指纹、人脸）等身份认证方式，验证用户身份；通过用户分组、权限分级，限制用户对系统资源的访问范围，防止权限滥用。
- **系统漏洞防护**：及时安装操作系统的安全补丁，修复已知漏洞；关闭不必要的端口、服务和进程，减少攻击面，避免攻击者利用漏洞入侵。
- **恶意代码防护**：安装杀毒软件、防火墙，实时监测和拦截恶意代码；定期对操作系统进行病毒扫描，清除已感染的恶意代码；禁止运行未知来源的程序，防范恶意代码植入。
- **文件与数据保护**：对操作系统的核心文件进行加密存储和权限保护，防止文件被篡改或删除；开启系统还原功能，当系统出现故障时，可快速恢复到正常状态。
- **系统审计与监控**：记录操作系统的所有操作行为（如用户登录、进程启动、文件修改），形成审计日志；实时监控系统运行状态、资源占用情况，及时发现异常行为和攻击迹象。
- **安全配置优化**：优化操作系统的安全配置，例如关闭文件共享、开启密码复杂度要求、设置账户锁定策略（多次密码错误锁定账户），提升操作系统的安全性。

3.3 协同防护要点

数据库与操作系统是信息系统的核心组成部分，两者的安全防护需协同推进，形成完整的安全防线。一方面，操作系统是数据库运行的基础，操作系统的安全直接影响数据库的安全，需先筑牢操作系统的安全屏障，防止攻击者通过操作系统入侵数据库；另一方面，数据库的安全防护需结合操作系统的安全机制，例如利用操作系统的权限管理，限制数据库用户的操作范围，利用操作系统的加密功能，保障数据库数据的存储和传输安全。

此外，需建立统一的安全管理体系，定期对数据库和操作系统进行安全检测、漏洞扫描和风险评估，及时排查安全隐患，制定协同应急响应预案，当发生安全事件时，快速处置，降低损失。

3.4 应用分析

3.4.1 企业信息系统领域

内容囊括：真题汇编+精华复习讲义+机考模拟系统+APP 刷题题库;本资料属于其中之一，紧扣考纲每年更新.获取本资料即获取所有模块内容,不需另付费
历年真题、考前押题等登录网站或者APP内在线做题，可计时考试答题/不计时刷题/背题

本资料由达海教育 www.wuyouqiuzhi.com 及旗下 APP【笔试通】独家提供不定期更新，仅限购买用户个人学习使用，不得分享/转增/转卖

企业信息系统（如 ERP 系统、CRM 系统）依赖数据库存储企业核心数据，依赖操作系统保障系统运行，需加强两者的协同防护。例如，企业通过优化操作系统安全配置、安装补丁，防范系统入侵；通过数据库加密、权限管理，保护企业商业机密和客户信息，防止数据泄露和篡改；定期进行安全审计，排查权限滥用和异常操作，保障企业信息系统的安全稳定运行。

3.4.2 金融领域

金融机构的核心系统（如银行核心业务系统、证券交易系统）对数据库和操作系统的安全性要求极高，需满足合规要求。例如，银行通过双重身份认证、数据库加密，保护用户的账户信息和交易数据；通过操作系统漏洞防护和恶意代码防护，抵御攻击，确保核心系统持续运行；定期进行数据备份和恢复演练，防止数据丢失，保障金融交易的安全。

3.4.3 政务领域

政务信息系统（如电子政务平台、政务数据中心）存储大量政务数据，需保障数据安全和系统稳定。例如，政务数据中心通过操作系统安全加固、数据库审计，防范政务数据泄露和篡改；通过协同防护机制，确保政务系统的核心数据库和操作系统安全，保障政务服务正常开展，维护政府公信力。

3.4.4 互联网领域

互联网平台（如电商平台、社交平台）的数据库存储海量用户信息，操作系统承载平台的运行，需强化安全防护。例如，电商平台通过数据库防火墙防范 SQL 注入攻击，保护用户的购物信息和支付数据；通过操作系统恶意代码防护，抵御 DDoS 攻击和恶意入侵，确保平台持续稳定运行，提升用户信任度。

3.4.5 工业领域

工业控制系统的数据库存储生产数据，操作系统控制工业设备的运行，需保障两者的安全，防止生产中断。例如，工业企业通过操作系统隔离防护，将生产网络与互联网隔离，防止外部攻击；通过数据库备份和权限管理，保护生产数据的完整性和安全性，确保工业控制系统的稳定运行。

4 信息系统工程与标准规范

4.1 信息系统工程基本概念

4.1.1 核心定义

信息系统工程是指围绕信息系统的规划、设计、开发、部署、运维、升级、报废等全生命周期，进行的一系列工程化活动，旨在构建安全、稳定、高效、合规的信息系统，满足用户的业务需求和安全需求。其核心是“工程化”，即将工程管理的理念和方法应用于信息系统的建设和运维，规范流程、控制风险、提升质量。

信息系统工程涵盖硬件工程（服务器、网络设备、存储设备的部署和调试）、软件工程（软件的开发、测试、部署）、网络工程（网络的规划、搭建、优化）、安全工程（安全防护体系的构建）等多个分支，是一门综合性的工程学科。

4.1.2 核心生命周期阶段

内容囊括：真题汇编+精华复习讲义+机考模拟系统+APP 刷题题库;本资料属于其中之一，紧扣考纲每年更新.获取本资料即获取所有模块内容,不需另付费
历年真题、考前押题等登录网站或者APP内在线做题，可计时考试答题/不计时刷题/背题

本资料由达海教育 www.wuyouqiuzhi.com 及旗下 APP【笔试通】独家提供不定期更新，仅限购买用户个人学习使用，不得分享/转增/转卖

1. **规划阶段**：明确用户的业务需求和安全需求，进行可行性分析（技术可行性、经济可行性、安全可行性），制定信息系统建设规划、安全规划和项目计划，确定系统的整体架构和核心功能。

2. **设计阶段**：根据规划方案，进行系统架构设计、硬件设计、软件设计、网络设计和安全设计，明确系统的组成部分、接口规范、安全防护方案，形成详细的设计文档，为后续开发和部署提供依据。

3. **开发与实施阶段**：按照设计文档，开展硬件采购与部署、软件开发与测试、网络搭建与调试、安全防护体系部署等活动，确保各组件符合设计要求，实现系统的核心功能和安全需求。

4. **测试阶段**：对信息系统进行全面测试，包括功能测试、性能测试、安全测试、兼容性测试等，排查系统的功能缺陷和安全漏洞，确保系统满足业务需求和安全标准。

5. **部署与运维阶段**：将测试通过的信息系统部署到实际运行环境，开展系统初始化、用户培训、日常运维（故障排查、漏洞修复、数据备份）等活动，确保系统持续、稳定、安全运行。

6. **升级与报废阶段**：根据业务需求的变化和技术的升级，对信息系统进行优化和升级，提升系统性能和安全性；当系统达到使用寿命或无法满足业务需求时，按照规范进行报废处理，确保数据安全销毁和设备合规处置。

4.1.3 核心管理要素

- **范围管理**：明确信息系统工程的建设范围，控制项目的需求变更，避免项目范围蔓延，确保项目按时、按质完成。
- **进度管理**：制定详细的项目进度计划，监控项目进度，及时调整进度偏差，确保项目在规定时间内完成各阶段任务。
- **成本管理**：控制项目的采购成本、开发成本、运维成本，避免成本超支，实现项目的经济效益最大化。
- **质量管理**：建立质量管理体系，规范各阶段的工程活动，通过测试、审核等手段，确保系统的质量和安全性，满足用户需求。
- **安全管理**：将安全理念融入信息系统生命周期的各个阶段，构建全面的安全防护体系，防范安全风险，保障系统和数据安全。
- **风险管理**：识别项目各阶段的风险（技术风险、安全风险、成本风险、进度风险），制定风险应对预案，及时处置风险，降低风险造成的损失。

4.2 信息系统安全标准规范

信息系统安全标准规范是保障信息系统安全、规范信息系统工程活动的重要依据，分为国际标准、国家标准、行业标准和企业标准四个层级，涵盖信息系统安全技术、安全管理、安全评估等多个领域。

4.2.1 国际标准

- **ISO/IEC 27000 系列标准**：全球最具影响力的信息安全管理体系标准，涵盖信息安全管理体系（ISMS）的建立、实施、审核和改进，核心标准包括：
  - ISO/IEC 27001：信息安全管理体系要求，规定了信息安全管理体系的核心要素和实施要求，是企业建立和认证信息安全管理体系的依据。

内容囊括：真题汇编+精华复习讲义+机考模拟系统+APP 刷题题库;本资料属于其中之一，紧扣考纲每年更新.获取本资料即获取所有模块内容,不需另付费 历年真题、考前押题等登录网站或者APP内在线做题，可计时考试答题/不计时刷题/背题

本资料由达海教育 www.wuyouqiuzhi.com 及旗下 APP【笔试通】独家提供不定期更新，仅限购买用户个人学习使用，不得分享/转增/转卖

- ISO/IEC 27002：信息安全控制实践指南，提供了具体的信息安全控制措施（如访问控制、数据加密、漏洞管理），用于支撑 ISO 27001 的实施。
- ISO/IEC 27005：信息安全风险管理标准，规范信息安全风险的识别、评估和处置流程。

- **ISO/IEC 20000 系列标准：**IT 服务管理体系标准，规范信息系统的运维服务，提升运维服务质量和安全性，包括服务管理体系的建立、实施和评估。
- **NIST SP 800 系列文档：**由美国国家标准与技术研究院（NIST）发布，涵盖信息系统安全技术、安全管理、安全评估等内容，例如 NIST SP 800-53（信息系统安全控制措施）、NIST SP 800-171（受控非机密信息安全要求），在全球信息安全领域具有广泛影响力。

4.2.2 国家标准

- **GB/T 22080-2016（ISO/IEC 27001：2013）：**《信息技术 安全技术 信息安全管理体系 要求》，等同采用 ISO 27001 国际标准，是我国企业建立和认证信息安全管理体系的国家标准。
- **GB/T 22081-2016（ISO/IEC 27002：2013）：**《信息技术 安全技术 信息安全控制实践》，等同采用 ISO 27002 国际标准，为我国企业提供信息安全控制措施的实践指南。
- **GB/T 30976 系列标准：**《信息安全技术 工业控制系统信息安全》，涵盖工业控制系统的安全要求、安全评估、安全防护等内容，适用于工业领域的信息系统安全建设。
- **GB/T 35273-2020：**《信息安全技术 个人信息安全规范》，规定了个人信息的收集、存储、使用、传输、删除等环节的安全要求，保障个人隐私信息安全。
- **GB 17859-1999：**《计算机信息系统 安全保护等级划分准则》，将计算机信息系统的安全保护等级分为五级（从第一级到第五级，安全等级逐级提升），明确各级的安全要求，是我国信息系统安全等级保护的核心依据。
- **网络安全等级保护 2.0 标准：**包括 GB/T 22239-2019《信息安全技术 网络安全等级保护基本要求》等一系列标准，替代原等级保护 1.0 标准，扩大了适用范围（涵盖云计算、物联网、大数据等新技术场景），提升了安全要求，是我国网络安全和信息系统安全的重要规范。

4.2.3 行业标准

- **金融行业标准：**由银保监会、证监会等监管机构发布，例如《银行业金融机构信息科技风险管理指引》《证券期货业信息安全保障管理办法》，针对金融行业的特殊性，提出信息系统安全建设和管理的具体要求。
- **政务行业标准：**由国务院办公厅、国家网信办等部门发布，例如《电子政务信息安全等级保护实施指南》《政务信息系统安全管理规范》，规范政务信息系统的安全建设和运维，保障政务数据安全。
- **电信行业标准：**由工信部发布，例如《电信网和互联网安全等级保护实施指南》《电信行业信息安全管理办法》，规范电信行业的信息系统和网络安全，保障电信服务的稳定和安全。

4.2.4 企业标准

企业根据自身的业务需求、技术特点和合规要求，在遵循国际标准、国家标准和行业标准的基础上，制定的内部信息系统安全标准和规范，例如企业内部的信息安全管理办法、软件开发安全规范、数据安全管理规范等，

内容囊括：真题汇编+精华复习讲义+机考模拟系统+APP 刷题题库;本资料属于其中之一，紧扣考纲每年更新.获取本资料即获取所有模块内容,不需另付费
历年真题、考前押题等登录网站或者APP内在线做题，可计时考试答题/不计时刷题/背题
笔试1对1助攻辅导联系VX：zhugongqiuzhi 2027版

本资料由达海教育 www.wuyouqiuzhi.com 及旗下 APP【笔试通】独家提供不定期更新，仅限购买用户个人学习使用，不得分享/转增/转卖

用于规范企业内部的信息系统工程活动和安全管理工作。

4.3 标准规范的应用要点

- **合规适配**：根据信息系统的应用场景、行业属性和数据类型，选择适配的标准规范，例如金融行业需遵循金融行业标准和网络安全等级保护 2.0 标准，政务系统需遵循政务行业标准和个人信息安全规范，确保系统建设和运维符合合规要求。
- **全生命周期落地**：将标准规范融入信息系统生命周期的各个阶段，例如规划阶段参考标准确定安全需求，设计阶段按照标准制定安全方案，运维阶段依据标准开展安全管理，确保标准规范的全面落地。
- **动态更新**：关注标准规范的更新迭代（如国际标准修订、国家标准发布），及时调整信息系统的安全建设和管理方案，确保系统始终符合最新的标准要求。
- **结合实际优化**：在遵循标准规范的基础上，结合企业的业务实际和技术能力，优化安全方案和管理流程，避免生搬硬套，实现合规性与实用性的平衡。

4.4 应用分析

4.4.1 企业信息系统建设

企业在信息系统建设过程中，需遵循 ISO 27000 系列标准、网络安全等级保护 2.0 标准等规范，构建信息安全管理体系，规范工程流程。例如，企业按照 ISO 27001 标准建立信息安全管理体系，明确安全职责和控制措施；按照网络安全等级保护 2.0 标准，对信息系统进行等级测评，整改安全隐患，确保系统达到相应的安全等级要求；结合企业标准，规范软件开发和运维流程，提升系统质量和安全性。

4.4.2 政务信息系统建设

政务信息系统建设需严格遵循政务行业标准和国家相关规范，保障政务数据安全和系统合规。例如，政务系统按照《电子政务信息安全等级保护实施指南》，开展等级保护建设和测评；按照《政务信息系统安全管理规范》，建立安全管理体系，规范政务数据的收集、存储和使用；遵循《个人信息安全规范》，保护公众的隐私信息，确保政务系统合规运行。

4.4.3 金融信息系统建设

金融信息系统建设需遵循金融行业标准和国家安全规范，满足监管要求。例如，银行按照《银行业金融机构信息科技风险管理指引》，建立信息科技风险管理体系；按照网络安全等级保护 2.0 标准和 ISO 27001 标准，构建全面的安全防护体系；遵循《证券期货业信息安全保障管理办法》，确保证券交易系统的安全稳定，保障金融数据的安全性和完整性。

4.4.4 工业信息系统建设

工业信息系统建设需遵循 GB/T 30976 系列标准和网络安全等级保护 2.0 标准，防范工业控制系统安全风险。例如，工业企业按照《信息安全技术 工业控制系统信息安全》标准，构建工业控制系统的安全防护体系，隔离生产网络与互联网；按照等级保护 2.0 标准，对工业信息系统进行等级测评，修复安全漏洞，确保工业生产的安全稳定。

内容囊括：真题汇编+精华复习讲义+机考模拟系统+APP 刷题题库;本资料属于其中之一，紧扣考纲每年更新.获取本资料即获取所有模块内容,不需另付费
历年真题、考前押题等登录网站或者APP内在线做题，可计时考试答题/不计时刷题/背题

本资料由达海教育 www.wuyouqiuzhi.com 及旗下 APP【笔试通】独家提供不定期更新，仅限购买用户个人学习使用，不得分享/转增/转卖

4.4.5 互联网平台建设

互联网平台建设需遵循《个人信息安全规范》《网络安全法》《数据安全法》等相关标准和法规，保障用户隐私和数据安全。例如，互联网平台按照《个人信息安全规范》，规范用户信息的收集和使用，获取用户同意后再收集敏感信息；按照网络安全等级保护 2.0 标准，构建安全防护体系，抵御恶意攻击；遵循 ISO 27001 标准，建立信息安全管理体系，规范平台运维流程。同时，结合平台业务特点（如社交、电商、短视频），制定企业内部安全标准，针对海量用户数据存储、内容传播、交易交互等核心场景，补充专项安全控制措施，确保平台合规运营。此外，互联网平台需遵循《网络信息内容生态治理规定》，落实内容安全管理责任，结合信息内容安全防护技术，开展内容审核和风险防控，遏制有害信息传播，防范虚假信息误导，筑牢平台安全防线，兼顾合规性与用户体验。

4.5 信息系统工程与标准规范的发展趋势

随着云计算、物联网、大数据、人工智能等新技术的快速发展，信息系统工程的边界持续拓展，标准规范也在不断迭代完善，呈现出三大发展趋势。一是“全域合规”成为核心导向，数据安全、个人信息保护相关标准与法规深度融合，覆盖信息系统全生命周期、全业务场景，对跨境数据流动、数据销毁、隐私计算等新型场景的规范逐步细化，倒逼互联网平台、企业、政务部门等主体落实全流程安全管控责任。二是“新技术适配”加速推进，针对云计算、边缘计算、工业互联网等新型信息系统架构，现有标准规范不断修订，新增专项安全要求，同时涌现出一批适配新技术的细分领域标准，填补新型场景的安全规范空白，实现技术发展与标准规范同频同步。三是“协同化管控”成为主流，国际标准、国家标准、行业标准、企业标准的衔接更加紧密，跨行业标准融合趋势明显，同时推动安全标准与工程管理标准协同，实现技术防护、管理规范、合规审核的一体化，提升信息系统工程的整体安全水平和质量效益。

4.6 核心总结

信息系统工程是构建安全、稳定、高效信息系统的核心载体，其全生命周期管理需贯穿工程化理念，兼顾范围、进度、成本、质量、安全等多维度管理要素，确保系统满足业务需求与安全要求。信息系统安全标准规范是工程建设与运维的重要依据，不同层级、不同领域的标准相互补充，为信息系统合规建设提供支撑，企业、政务、金融、工业、互联网等不同场景需结合自身属性，适配对应的标准规范，实现合规与实用的平衡。未来，信息系统工程将向智能化、协同化、安全化方向发展，标准规范将持续适配新技术、新场景，推动信息系统安全防护体系升级，为数字经济高质量发展提供保障。

鉴于本资料不断发现被转卖/倒卖/分享/转赠。这是对我们劳动成果的亵渎，因此我们极不愿意却不得不做恶毒的声明以保护我们资料的价值；保证从我们处购买该资料的权益（付出的价格）

声明

本资料由 www.wuyouqiuzhi.com 及旗下淘宝店：天天向上求职工作室（唯一客服：galerjim）或职场精英工作室（唯一客服：蔚蓝小小天使）提供，或者下载移动端刷题软件（名称为：笔试通）亦可购买；若发现你的资料不是以上渠道获得，请前往以上渠道购买

祝所有从该处购买资料的用户顺利通过各个公司招聘笔试面试取得心仪 offer，一堆offer。祝所有从别处购买/分享获得/获赠该资料却仍然不通过上述渠道购买的用户笔试面试统统挂掉，祝所有转卖/倒卖/分享/转赠我们资料的商家/机构/个人的全家人灭绝，户口销户

内容囊括：真题汇编+精华复习讲义+机考模拟系统+APP 刷题题库;本资料属于其中之一，紧扣考纲每年更新.获取本资料即获取所有模块内容,不需另付费

历年真题、考前押题等登录网站或者APP内在线做题，可计时考试答题/不计时刷题/背题